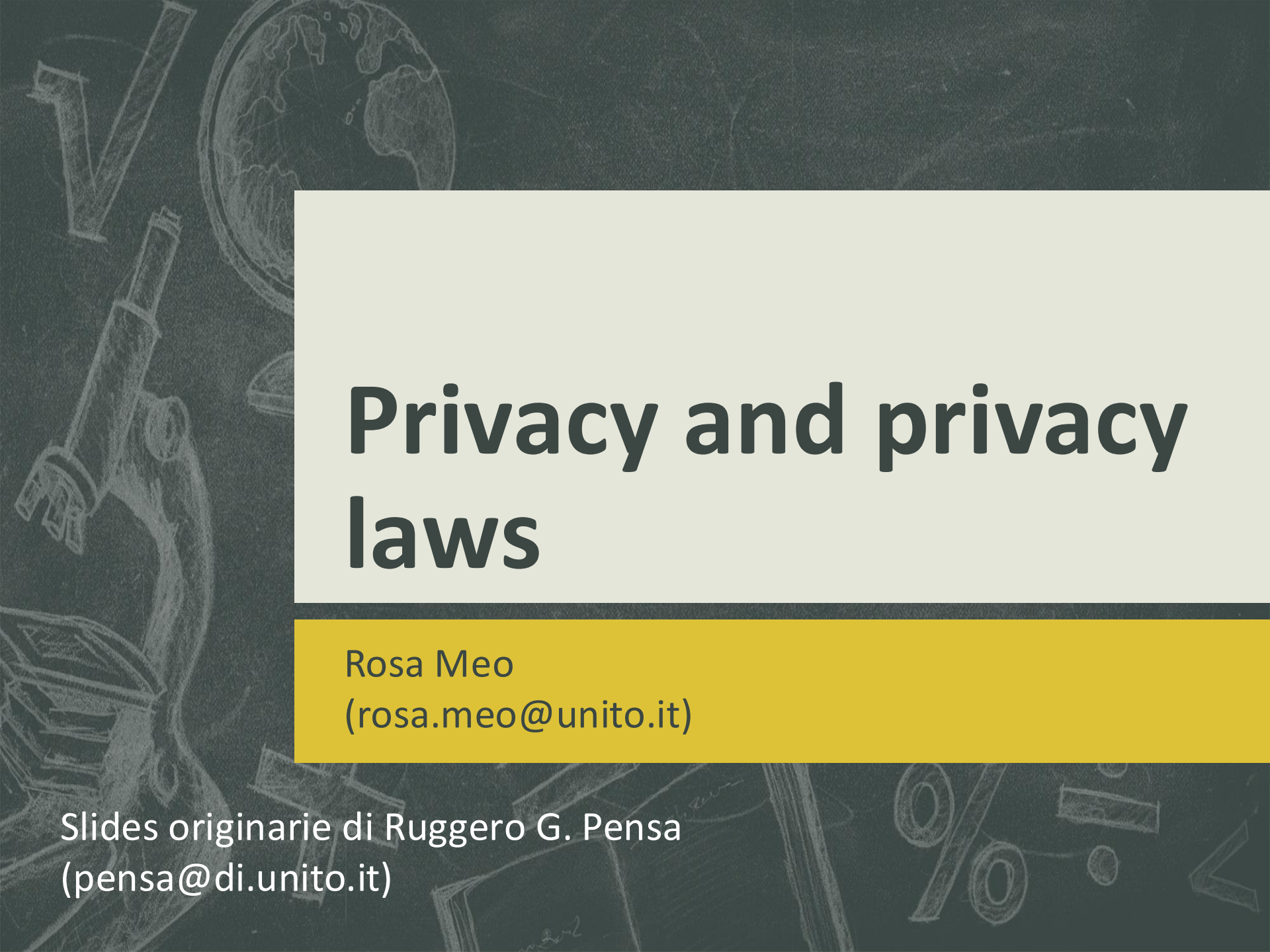




Privacy and privacy laws

Rosa Meo
(rosa.meo@unito.it)

Slides originarie di Ruggero G. Pensa
(pensa@di.unito.it)

Question 1

What is **privacy**?

What is privacy?

Privacy = the right to be alone

- Warren and Brandeis (1890): *The Right to Privacy*
 - One of the most influential essays in the history of American law
 - The authors were trying to find a legal rationale to protect privacy under then-existing statutes and principles
- Examples: the right of a person to choose seclusion from the attention of others, the right to be immune from scrutiny or being observed in private settings, such as one's own home

What is privacy?

Privacy = limited access

- a person's ability to participate in society without having other individuals and organizations collect information about them
- privacy as a system for limiting access to one's personal information
- Godkin (1880): "nothing is better worthy of legal protection than private life, or, in other words, the right of every man to keep his affairs to himself, and to decide for himself to what extent they shall be the subject of public observation and discussion."
- Bok (1989): privacy is "the condition of being protected from unwanted access by others—either physical access, personal information, or attention."

What is privacy?

Privacy = control over information

- Westin and Blom-Cooper (1970): "privacy is the claim of individuals, groups, or institutions to determine for themselves when, how, and to what extent information about them is communicated to others."
- Fried (1968): "Privacy is not simply an absence of information about us in the minds of others; rather it is the control we have over information about ourselves."

Standardized and legal definitions

Computer Security Guidelines for Implementing the Privacy Act of 1974 (NIST)



- FIPS PUB 41: “The right of an entity . . . to determine the degree to which it will interact with its environment, including the degree to which the entity is willing to share its personal information with others”
- ISO: “The right of individuals to control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed”

Retained definition

- Privacy is the ability of a person to control the availability of **information about** and **exposure of** him or herself
- It is related to being able to function in society **anonymously** (including pseudonymous or blind credential identification)

Why privacy matters

- Glenn Greenwald was one of the first reporters to see -- and write about -- the Edward Snowden files, with their revelations about the United States' extensive surveillance of private citizens.

In this [TED talk](#), Greenwald makes the case for why you need to care about privacy, **even if you're "not doing anything you need to hide."**



Question 2

Why is **privacy** so important?

Why privacy?

Privacy is an important issue today

- Individuals feel
 - Uncomfortable: ownership of information
 - Unsafe: information can be misused (e.g., identity thefts)
- Enterprises need to
 - Keep their customers feel safe
 - Maintain good reputations
 - Protect themselves from any legal dispute
 - Obey legal regulations

Question 3

Which types of **privacy** do you know?

Types of privacy

- Political privacy
- Consumer privacy
- Medical privacy
- Private property
- *Information technology end-user privacy
(also called **information/data privacy**)*

Data Privacy

- **Data Privacy** problems exist wherever uniquely identifiable data relating to a person or persons are collected and stored, in digital form or otherwise
- The most common sources of data that are affected by data privacy issues are:
 - Healthcare records
 - Criminal justice investigations and proceedings
 - Financial institutions and transactions
 - Biological traits, such as genetic material
 - Residence and geographic records
 - Location-based service and geolocation
 - Web surfing behavior or user preferences using persistent cookies

Data Privacy

- The challenge in data privacy is to **share data** while **protecting** the personally identifiable information
 - Consider the example of health data which are collected from hospitals in a district; it is standard practice to share this only in aggregate form
 - The idea of sharing the data in aggregate form is to ensure that only non-identifiable data are shared
- The legal protection of the right to privacy in general and of data privacy in particular **varies greatly around the world**

Privacy laws and regulations

- Privacy law in the United States
- Privacy law in the European Union
 - Privacy law in Italy
 - General Data Protection Regulation
- Transnational regulations

Data Privacy Laws in the United States



Data privacy is **not** highly legislated or regulated in the US

- No all-encompassing law regulating the acquisition, storage, or use of personal data
- If someone collect some data (even without permission), it is deemed to own the right to store and use it
- Example: third-party credit reports may be sought when seeking employment or medical care, or making automobile, housing, or other purchases on credit terms
- Some exceptions exist

Data Privacy Laws in the United States



- Health Insurance Portability and Accountability Act (HIPAA)
- Children's Online Privacy Protection Act (COPPA)
- Fair Credit Reporting Act (FCRA)
- Computer security and Privacy Laws:
 - 1986 U.S. Electronic Communications Privacy Act (ECPA)
 - 1988 U.S. Video Privacy Protection Act
 - 2001 U.S. Provide Appropriate Tools Required to Intercept and Obstruct Terrorism (PATRIOT) Act

Privacy law in the European Union



Contrary to the US, the right to data privacy is **heavily regulated** and actively enforced in Europe

- Article 8 of the European Convention on Human Rights (ECHR) provides a right to respect for one's "private and family life, his home and his correspondence"
- The European Court of Human Rights has given this article a very broad interpretation in its jurisprudence, including:
 - gathering information for the official census
 - recording fingerprints and photographs in a police register
 - collecting medical data or details of personal expenditures
 - implementing a system of personal identification

The two EU privacy eras



1995 – 2018

- Data Protection Directive (95/46/EC)

2018 – ...

- General Data Protection Regulation (GDPR) (EU) 2016/679

Data Protection Directive



- The **Data Protection Directive (95/46/EC)** was adopted by the European Parliament in 1995
 - attempt to harmonizing data protection law within the EU
 - to be transposed into national law by the end of 1998
- Anyone processing personal data had to comply with the eight enforceable principles of good practice. Data had to be:
 1. **Fairly** and lawfully processed
 2. Processed for **limited purposes**
 3. **Adequate, relevant** and not excessive
 4. **Accurate**
 5. Kept **no longer than necessary**
 6. Processed in accordance with the data **subject's rights**
 7. **Secure**
 8. **Transferred only to countries** with adequate protection

Definitions



Personal data were defined as “any information relating to an identified or identifiable natural person ("data subject"); an identifiable person is one who can be identified, directly or indirectly, in particular by reference to an identification number or to one or more factors specific to his physical, physiological, mental, economic, cultural or social identity”

- Small (but important) changes in the GDPR

Definitions



Data processing meant “any operation or set of operations which is performed upon personal data, whether or not by automatic means, such as collection, recording, organization, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, blocking, erasure or destruction”

- Small changes in the GDPR

Definitions



Titolare del
 trattamento

The **responsibility** for compliance rested on the shoulders of the "**controller**", i.e., the natural or artificial person, public authority, agency or any other body which alone or jointly with others **determined the purposes and means of the processing** of personal data

Processor: a natural or legal person, public authority, agency or any other body which processes personal data on behalf of the controller

- No significant changes in the GDPR

Principles



Personal data should not have been processed at all, except when three categories of conditions were met:

- **Transparency:** the data subject had the right **to be informed** when his personal data is being processed. The controller had to provide all information required to ensure the processing was fair (e.g., purpose, recipient...)
- **Legitimate purpose:** personal data could only be processed for specified legitimate purposes and might **not be processed further** in a way incompatible with those purposes
- **Proportionality:** personal data processing should have been adequate, relevant and not excessive **in relation to the purposes** for which personal data were collected and/or further processed

Transparency



Data might be processed only if at least one of the following was true:

- the data subject had given his **consent**
- the processing was necessary for the **performance of a contract**
- processing was necessary **for compliance with a legal** obligation
- processing was necessary in order to **protect the vital interests** of the data subject
- processing was necessary for the task carried out in **the public interest**
- processing was necessary for the **purposes of the legitimate interests pursued by the controller, except where such interests were overridden** by the interests for fundamental **rights and freedoms of the data subject**

Transparency



The data subject had the **right** to

- **access** all data processed about him
- demand the **rectification**, **deletion** or **blocking** of data that is incomplete, inaccurate or not being processed in compliance with the data protection rules

Proportionality



- Data had to be accurate and, where necessary, kept up to date
- Data shouldn't have been kept in a form which permits identification of data subjects for longer than is necessary
- Member States had to lay down appropriate safeguards for personal data stored for longer periods for historical, **statistical** or **scientific** use
- Extra restrictions applied to **sensitive** personal data (religious beliefs, political opinions, health, sexual orientation, race, membership of past organisations)
- The **data subject might object at any time** to the processing of personal data for the purpose of **direct marketing**
- A decision which produces legal effects or significantly affects the data subject might not be based solely on automated processing of data
- A form of appeal should have been provided when automatic decision making processes were used

Privacy authorities



- Each member state had to set up a **supervisory authority** that
 - had to **monitor the data protection** level in that member state
 - gave **advice to the government about administrative measures** and regulations
 - **started legal proceedings** when data protection regulation has been violated
- The **controller** had to notify the **supervisory authority** the following information
 - the name and address of the controller
 - the **purposes** of the processing
 - a **description of the categories of data subject** and of the data or categories of data relating to them
 - the **recipients** to whom the data might be disclosed
 - proposed transfers of data to **third countries**
 - a general description of the **measures taken to ensure security** of processing
- This information is kept in a **public register**

Privacy Law in Italy



In Italy, Directive 95/46/EC on data protection (Data Protection Directive) was implemented by Legislative Decree No. 196/2003, which contained the **Italian Personal Data Protection Code** (*Codice in materia di protezione dei dati personali*)

In addition, the **Italian Data Protection Authority** (*Garante per la protezione dei dati personali*) was committed to issuing **appropriate measures** with regard to many areas including (but not limited to):

-
- **Video surveillance**
 - **Biometric** data processing
 - **Health** data processing
 - **Data breach notifications**
 - **Bank information** processing
 - **E-health** records
 - **Online profile**
 - Data **processing carried out by system administrators**
 - Data processing **for marketing and profiling** purposes
 - **Mobile payment**
 - **Cookies**
-

General Data Protection Regulation



- The General Data Protection Regulation (GDPR) (Regulation (EU) 2016/679) is a **regulation (not just a directive)** by which the EU members intend to **strengthen and unify data protection for all individuals within the European Union (EU)**
- The primary objectives of the GDPR are to give citizens and residents back control of their personal data and to simplify the regulatory environment for international business by unifying the regulation within the EU
- The regulation was adopted on 27 April 2016
- It applies since **25 May 2018** after a two-year transition period and, unlike a directive, it **does not require any enabling legislation** to be passed by national governments

Definitions



Personal data: any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, **location data**, an **online identifier** or to one or more factors specific to the physical, physiological, **genetic**, mental, **economic**, **cultural** or social identity of that natural person

Definitions



Processing: any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organisation, **structuring**, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction

Definitions



Pseudonymisation: the processing of personal data in such a manner that the **personal data can no longer be attributed to a specific data subject without the use of additional information;**

such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person

Definitions



Personal data breach: a breach of security leading to the accidental or unlawful **destruction, loss, alteration, unauthorised disclosure of, or access to**, personal data transmitted, stored or otherwise processed

Data subject's rights



GDPR lists the rights of the data subject, that is the individual whose personal data is being processed

These strengthened rights give individuals more control over their personal data, including through

- the need for the individual's **clear consent** to the processing of personal data
- **easier access** by the subject to his or her personal data
- the rights to rectification, to erasure and “**to be forgotten**” → oblio
- the **right to object**, including to the use of personal data for the purposes of “profiling”
- the right to **data portability** from one service provider to another

Privacy by Design and by default



- GDPR aims at enforcing **Privacy by Design and by Default**
- Privacy by Design and by Default requires that data protection is **designed into the development of business processes** for products and services
- Privacy settings must be set at a **high level by default**
- Technical and procedural measures should be taken care by the controller in order to make sure that the processing, **throughout the whole processing lifecycle**, complies with the regulation
- Controllers should also implement mechanisms to ensure that **personal data is only processed when necessary for each specific purpose.**

Privacy by Design



- Privacy by Design [Ann Cavoukian, 2012] is an approach to systems engineering which takes privacy into account throughout the whole engineering process
- Based on 7 foundational principles:
 1. Proactive not reactive; Preventative not remedial
 2. Privacy as the default setting
 3. Privacy embedded into design
 4. Full functionality – positive-sum, not zero-sum
 5. End-to-end security – full lifecycle protection
 6. Visibility and transparency – keep it open
 7. Respect for user privacy – keep it user-centric

Pseudoanonymization



- The GDPR refers to **pseudonymisation** as a process that transforms personal data in such a way that the resulting data cannot be attributed to a specific data subject without the use of additional information
 - E.g., **encrypting the data locally, keeping the decryption keys separately** from the encrypted data
- If the personal data is pseudonymised with adequate internal policies and measures, then it is considered to be effectively anonymized, and **not subject to controls and penalties** of the GDPR
- The regulation does not concern the processing of information that is deemed anonymous, **including for statistical or research purposes**
- The policies and measures that meet the principles of **data protection by design and data protection by default** should be considered adequate for this purpose

Responsibility and accountability



- To be able to demonstrate **compliance with the GDPR**, the **data controller** must implement measures which meet the principles of **data protection by design and by default**
- It is the responsibility and the liability of the data controller to implement effective measures and be able to **demonstrate the compliance** of processing activities

Responsibility and accountability



- Users must be clearly informed about the **extent** of data collection, the **legal basis** for processing of personal data, **how long** data is retained, if data is being **transferred to a third-party** and/or outside the EU, and **disclosure of any automated decision-making** that is made on a solely-algorithmic basis
- Users must be provided with contact details for the **data controller** and their designated **Data Protection Officer**, where applicable
- Users must also be informed of their privacy rights under GDPR

Responsibility and accountability



- **Data protection impact assessments (DPIA)** have to be conducted **when specific risks occur** to the rights and freedoms of data subjects
- Risk assessment and mitigation is required and **prior approval** of the **national data protection authorities (DPAs)** is required for **high risks**
- **Records of processing activities** must be maintained that include **purposes of the processing**, categories involved and envisaged **time limits**
- The records must be made available to the supervisory authority on request

Data Protection Officer (DPO)



- GDPR establishes the figure of the **Data Protection Officer (DPO)**, a person with expert knowledge of data protection law and practices that should assist the controller or processor to monitor internal compliance with this Regulation
- The DPO are also expected to be proficient at **managing IT processes, data security** (including dealing with cyber-attacks) and other **critical business continuity issues** around the holding and processing of personal and sensitive data
- Public authorities, and businesses whose core activities centre around regular or systematic processing of personal data, are **required to employ a DPO**

Data breaches



- **The data controller is under a legal obligation to notify the supervisory authority without undue delay** unless the breach is unlikely to result in a risk to the rights and freedoms of the individuals
- There is a maximum of **72 hours** after becoming aware of the data breach to make the report
- **Individuals have to be notified** if adverse impact is determined
- **The data processor will have to notify the controller** without undue delay after becoming aware of a personal data breach
- However, the **notice to data subjects is not required** if the data controller has implemented appropriate technical and organisational protection measures that render the **personal data unintelligible** to any person who is not authorised to access it, such as **encryption**

Sanctions



The following sanctions can be imposed:

- a warning in writing in cases of first and non-intentional noncompliance
- regular periodic data protection audits
- a fine up to €10 million or up to 2% of the annual worldwide turnover of the preceding financial year in case of an enterprise, if there has been an infringement of some obligations
- a fine up to €20 million or up to 4% of the annual worldwide turnover of the preceding financial year in case of an enterprise, if there has been some severe violations of the principles

Transnational regulations



- Safe Harbor privacy principles (fino al 2015)
- EU-US Privacy Shield (2016-2020)
- EU-US Data Privacy Framework (2023- ad oggi)

Safe Harbor Privacy Principles



Developed between 1998 and 2000 in order to prevent private organizations within the EU or US from accidentally disclosing or losing personal information

US companies storing customer data could self-certify that they adhered to 7 principles:

1. **Notice:** individuals must be informed that their data is being collected and how it will be used
2. **Choice:** individuals must have the option **to opt out of the collection and forward transfer of the data to third parties**
3. **Onward Transfer:** transfers of data to third parties may only occur to other organizations that **follow adequate data protection** principles
4. **Security:** reasonable efforts must be made to prevent loss of collected information
5. **Data Integrity:** data must be **relevant and reliable** for the **purpose** it was collected
6. **Access:** individuals must be able to **access, correct and delete** information held about them
7. **Enforcement:** there must be **effective means of enforcing these rules**

Safe Harbor - History



- The European Commission made a decision in 2000 that the United States' principles did comply with the EU Directive (the so-called "Safe Harbour decision")
- After a customer complained that his Facebook data were insufficiently protected, the European Commission Court of Justice declared **in October 2015 that the Safe Harbour Decision was invalid**
- Further talks have been held by the Commission with the US authorities towards "a renewed and sound framework for transatlantic data flows"
- The European Commission and the United States agreed to establish a new framework for transatlantic data flows on 2nd February 2016, known as the **"EU-US Privacy Shield"**

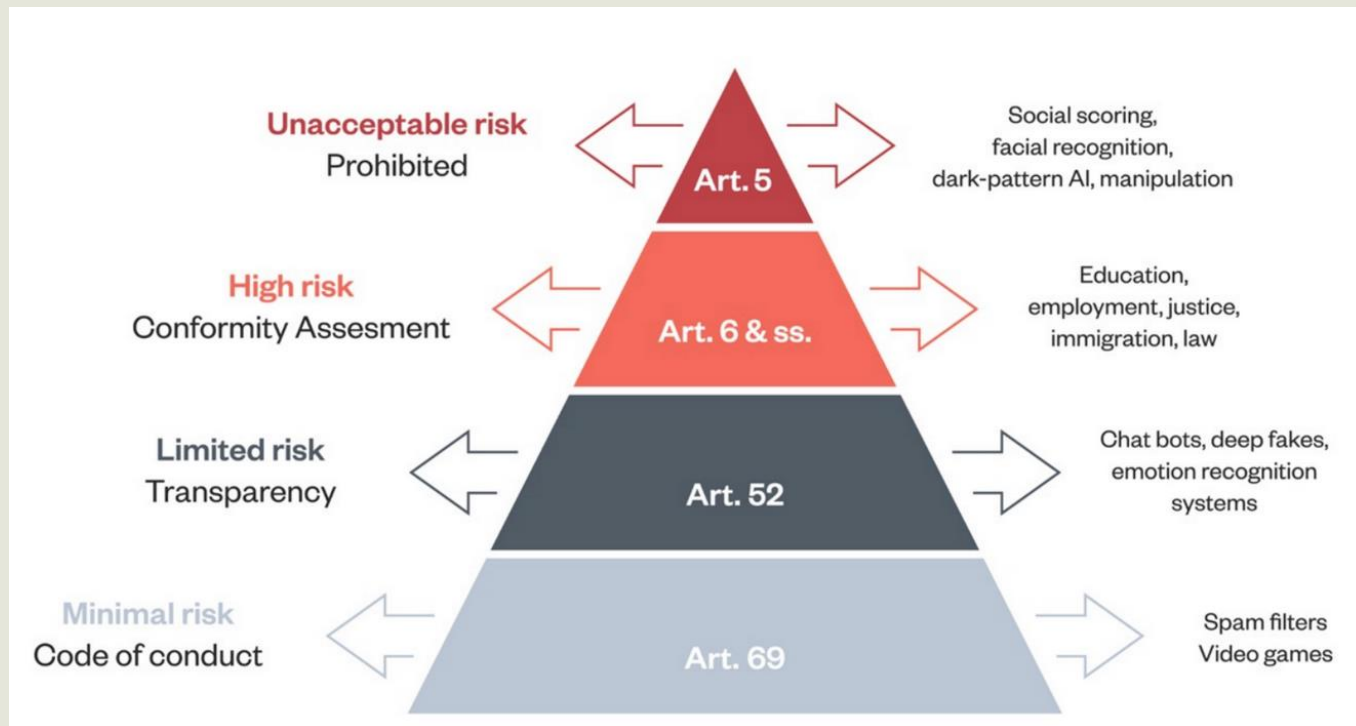
EU-US Privacy Shield



- The **EU-US Privacy Shield** is a framework for transatlantic exchanges of personal data for commercial purposes between the European Union and the United States
 - One of its purposes is to enable US companies to more easily receive personal data from EU entities under EU privacy laws meant to protect European Union citizens
 - The European Commission adopted the framework on **12 July 2016** and it went into effect the same day
 - U.S. President Donald Trump signed an Executive Order entitled “Enhancing Public Safety” which states that U.S. **privacy protections will not be extended beyond US** citizens or residents
 - On July 2020 the EU-US Privacy Shield **was struck down by the European Court of Justice** as it **did not provide adequate protections to EU citizens on government snooping**
 - Transfers on the basis of this legal framework **are declared illegal**
- Spionaggio governativo

AI Act (from 1st of August 2024, in EU)

- AI Act aims to ensure that AI systems used within the EU are safe, transparent, and respect fundamental rights.
- The AI Act **categorizes AI systems based on the level of risk they pose:**

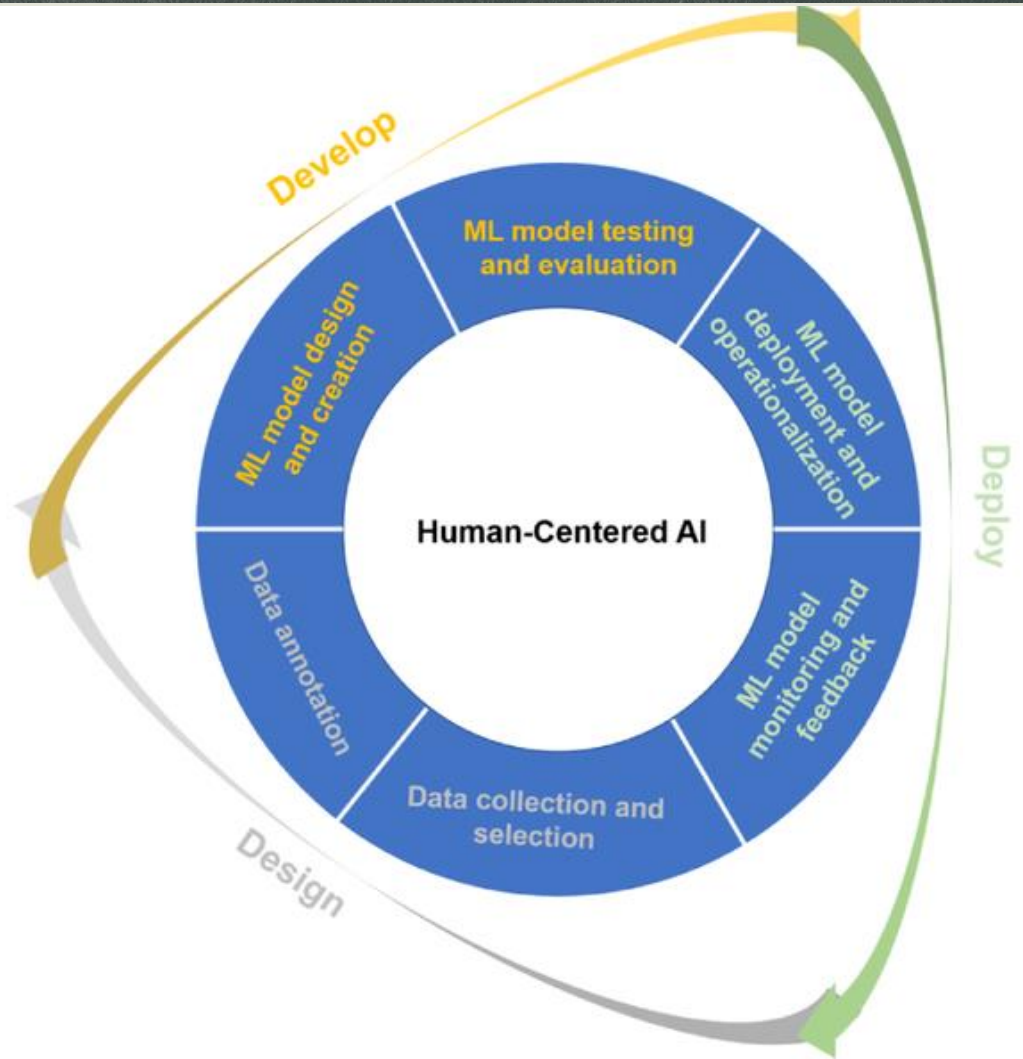


AI Act: description of the levels of risk

- 1. Unacceptable Risk:** AI systems that pose a clear threat to safety or fundamental rights are prohibited.
This includes systems that deploy subliminal techniques to *manipulate behavior*, *exploit vulnerabilities of specific groups*, or enable *social scoring by governments*.
- 2. High Risk:** AI systems used in critical areas such as *healthcare, education, employment, law enforcement*, and *essential services* are subject to strict obligations.
These include rigorous risk assessments, data governance measures, human oversight, and continuous monitoring to ensure compliance.
- 3. Limited Risk:** AI systems with limited risk, such as *chatbots* and *deepfakes*, are subject to *transparency obligations*.
Providers and deployers *must inform users that they are interacting* with an AI system.
- 4. Minimal Risk:** The majority of AI systems, like AI-enabled *video games* or *spam filters*, fall under this category and are largely *unregulated*, encouraging innovation and development.

AI Act for General Purpose AI (GPAI)

- It imposes specific requirements on GPAI providers.
- All GPAI model providers must:
 - Provide technical documentation and usage instructions
 - Comply with the EU Copyright Directive
 - Publish a summary of the training data used
 - Conduct model evaluations and adversarial testing for models presenting systemic risks
 - Ensure robust cybersecurity protections.



AI Act: Obligations for Providers and Users

- **Providers (Developers):** Entities that develop high-risk AI systems **must implement a risk management system**, ensure **high-quality datasets**, maintain detailed **technical documentation**, and design systems with appropriate levels of **accuracy, robustness, and cybersecurity**
- **Users (Deployers):** Organizations deploying high-risk AI systems are required to use these systems as intended, **monitor their performance**, and **ensure human oversight** to prevent and mitigate risks.

AI Act: Governance and Enforcement:

- The AI Act establishes the European Artificial Intelligence Board
- it oversees implementation and ensure consistent application across Member States
- National competent authorities are designated to supervise and enforce compliance within their jurisdictions

Digital Services Act (DSA, approved in 2022)

- The DSA is a European Union regulation aimed at creating a **safer digital space**, where users' fundamental rights are protected and a level playing field is established for businesses.
- The key principle is: “what is illegal offline must also be illegal online.”
- The code contains 44 commitments and 128 measures covering four principal areas:
 - **Demonetization:** Reduction of financial incentives for leakers of misinformation
 - **Transparency of political advertising:** more efficient labeling to allow users to recognize political advertising
 - Guarantee the **integrity of services:** reduction of *fake accounts, amplification driven by bots, malicious deepfakes*, and other *manipulative* behavior used to *spread disinformation*
 - Empower users, researchers and the **fact-checking** community: better tools to help users identify the disinformation, wider access to data, fact-checking coverage the whole EU

Digital Services Act (DSA) (2)

- DSA does not require the removal of content that is harmful but legal (such as disinformation in the broad sense), but focuses on illegal content (hate speech, counterfeit goods, child pornography).
- Reporting mechanisms (“Notice and Action”): Platforms must provide easy tools for reporting illegal content.
- Transparency: Platforms must explain to users why content has been removed or restricted, and offer the possibility of appeal.
 - Recommendation algorithms
 - Advertising transparency
 - Prohibition of profiling: Targeted advertising based on sensitive data (sexual orientation, religion, ethnicity) or aimed at minors is prohibited.

Digital Services Act (DSA) (3)

- **Protection of Minors**

- The DSA imposes enhanced measures to protect minors online, ensuring high levels of privacy, safety, and security in their digital spaces, reducing exposure to inappropriate content.

- **Accountability and Sanctions**

- National Coordinators: Each member state appoints a coordinator to oversee compliance with the rules.
- Heavy penalties: In the event of non-compliance, the European Commission can impose fines of up to 6% of the platforms' global annual turnover.
- The DSA, together with the Digital Markets Act (DMA), is the cornerstone of the European strategy for a safer and fairer digital single market.

The Data Act in EU (from September 2025)

- The EU Data Act, in force as of September 2025, grants users (individuals and businesses) greater control over **data generated by connected devices (IoT)** and services.
- It mandates that manufacturers make this data accessible to users, enabling **data portability**, switching between cloud providers, and protecting against unfair contract terms.
- Key aspects of the Data Act include:
 - **User Data Access & Control:** Users can access and share data generated by products (e.g., smart home devices, cars, industrial machinery) with **third parties**.
 - **Fairness in Data Sharing:** It restricts manufacturers from imposing unfair contractual terms, prohibiting them from locking users into proprietary services.
 - **Cloud Switching:** The Act facilitates moving data and applications between different cloud service providers without cost, thus increasing competition.
 - **Public Sector Access:** Public bodies can request data from private companies in "exceptional" situations, such as public emergencies or to fulfill specific tasks.
 - **International Transfers:** Rules are introduced to **prevent** unlawful **third-country government access to non-personal data**.
- This legislation aims to foster a fairer, more competitive data economy across the EU by promoting innovation in after-sale services and improving data portability.

Digital Omnibus (proposal in November 2025)

- It is a package of proposals presented by the European Commission on November 19, 2025, aimed at simplifying and streamlining the EU's digital regulatory framework, including GDPR, AI Act, and NIS2 (network and information system security in 18 critical sectors such as energy, transport, healthcare, finance, water supply, digital infrastructure, postal services, public administration, and aerospace)
- Its primary objective is **to reduce bureaucracy** for businesses, especially SMEs, while maintaining citizen protections and improving user experience and efficiency.
- The proposals include clarifying GDPR application regarding **personal data and legitimate interest**, simplifying **cookie regulations**, making **AI** rules more innovation-friendly with mechanisms like *stop-the-clock*, introducing a **Single-Entry Point for cybersecurity incident reporting**, and extending the data breach notification period to **90 hours**.

An example: relaxation on the privacy protection in personal data (from page 10 of omnibus proposal (Italian version))

- To determine whether a natural person is identifiable, it is appropriate to **consider all means that are likely to be reasonably used to identify that person**, either directly or indirectly.
- The **existence of additional information** enabling the identification of the data subject **does not imply that pseudonymized data should be considered, in all cases** and for every person or entity, and personal data for the purposes of applying Regulation (EU) 2016/679 (General Data Protection Regulation or GDPR).
- In particular, it should be clarified that **the information should not be considered personal data for a given entity if that entity does not have the means that can reasonably be used to identify the natural person.**

Example 2: processing personal data to eliminate bias in datasets and protecting subjects from discriminations (from page 11)

- It is appropriate to assess whether the interest pursued by the data controller is beneficial to the data subject and society in general
- For example, where the **processing of personal data is necessary to identify and eliminate distortions**, thereby protecting data subjects from **discrimination**
- The processing of personal data for **scientific research purposes pursues a legitimate interest** within the meaning of Article 6(1)(f) of Regulation (EU) 2016/679 (**GDPR**), provided that such research is not contrary to the law of the Union or of the Member States.
 - Legitimate interest serves as the legal basis for data processing **without the need for explicit consent**, provided that the processing is necessary and that the interests or fundamental rights and freedoms of the data subject do not override the legitimate interests (it is necessary to balance the two rights: the corporate legitimate interest and the subject's privacy rights).

Example 3: collection of personal data in training and validation sets in AI/ML (pag 12)

- The development of certain **AI systems** and models may involve the **collection of large amounts of data, including personal data** and special categories of such data.
- In order not to **disproportionately hinder the development and functioning of AI** and taking into account the capabilities of the data controller to identify and remove special categories of personal data (sensitive), an **exception to the prohibition on processing** special categories of **personal data should be allowed**.
- This derogation should only apply if the **controller has effectively implemented appropriate technical** and organizational measures to **prevent the processing of such data**, takes appropriate measures throughout the entire life cycle of an AI system or model, and, once identified, **effectively removes such data**.
- Where removing the data would require a **disproportionate effort**, in particular if the removal of specific categories of data stored in the AI system or model would **require the re-engineering of that system** or model, **the controller should effectively protect such data** so that it is not used to derive outputs, disclosed or otherwise made available to third parties.

Conclusions

- What do you think about privacy?
- And about legislation on it?
- Fill our (anonymous) survey so that we can discuss on the answers

Alternatively, for the survey, go to:
<https://di.unito.it/myquestions>



SCAN ME